IDOR Testing Advanced

Educational Bug Bounty Series • Authorized Security Research Only

■ IDOR & Broken Object-Level Authorization — Advanced Testing

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope and ethics: *Use two test accounts you control and synthetic records. Never access or modify another real user's data.*

■ Executive Summary

IDOR/BOLA occurs when an application fails to verify that the current user may access a requested object. The supplied *IDOR 2.pdf* lists methods, parameter names, paths, content types, identifier formats, API versions, and GraphQL as testing areas.

■ Core Testing Methodology

1. Create two controlled accounts and harmless records owned by each.
2. Identify object IDs in paths, query strings, request bodies, and GraphQL operations.
3. Confirm each account can access its own records but not the other's.
4. Review read, update, delete, export, and sharing operations using synthetic records only.
5. Check that all supported methods and content types enforce authorization.
6. Review duplicate parameters, alternate path forms, and structured JSON values in a lab.
7. Check documented legacy API versions and GraphQL nested resolvers.
8. Document the permission rule, controlled result, and redacted evidence.

■ High-Value Bug Bounty Tips & Edge Cases

- Predictable IDs are not required for IDOR; opaque or encoded IDs are not authorization controls.
- Duplicate parameters may be parsed differently by gateways and applications.
- Method changes and content-type changes must not bypass authorization.
- Legacy API versions may have inconsistent controls.
- GraphQL must enforce permissions in nested resolvers and batch operations.
- Wildcard and bulk endpoints must filter each returned object.
- The PDF contains many bypass-shaped examples; this guide groups them into safe test categories rather than reproducing a bulk list.

■■ Educational Checklists & Safe Examples

```
GET /api/v1/records/[OWN-TEST-RECORD-ID] HTTP/1.1
Host: example.com
Authorization: Bearer [TEST-ACCOUNT-A-TOKEN]
```

- [ ] Every object action checks ownership and permissions.
- [ ] Duplicate parameters are rejected or parsed consistently.
- [ ] All API versions and methods enforce the same policy.
- [ ] GraphQL nested and batch operations enforce authorization.
- [ ] Tests use only synthetic records.

■■ Mitigation & Remediation

Enforce server-side object-level authorization on every action, scope database queries to permitted objects, reject ambiguous parameters, apply consistent controls across API versions and methods, and add regression tests using separate owners.

Source Notes

Based on the supplied two-page *IDOR 2.pdf*. Page 1 lists baseline checks, method and parameter variations, path handling, content types, ID formats, and role-level routes. Page 2 covers indexed endpoints, hidden parameters, parameter pollution, JSON structures, API versions, and GraphQL.

Educational use only. Test only records you control.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.